CORVANE SYSTEMS

Document ID	PRV-004
Version	2.2
Effective date	1 January 2026
Owner	Data Protection Officer (DPO), with the Incident Response Team
Applies to	All employees and contractors

Personal Data Breach Response Procedure

1. What is a personal data breach?

A personal data breach is a security incident that leads to the accidental or unlawful **destruction, loss, alteration, unauthorised disclosure of, or access to** personal data. Breaches fall into three types:

Type	Meaning	Example
Confidentiality breach	Personal data is disclosed to, or accessed by, someone who should not see it.	An email with a customer's driver list is sent to the wrong customer.
Integrity breach	Personal data is changed without authorisation.	A bug overwrites the addresses of customer contacts with wrong values.
Availability breach	Personal data is lost or cannot be accessed.	Ransomware encrypts the HR file share and no backup can be restored.

A breach does not have to involve hackers. Most breaches at Corvane are caused by human error, such as a wrong email recipient, a misconfigured sharing link or a lost laptop.

2. Step 1: report internally (everyone)

If you discover or suspect a breach, report it to the **Security Desk** at ext. 4444 or security@corvane.example **immediately, and at the latest within 1 hour** of discovering it. The Security Desk is staffed 24/7.

When you report, say:

- what happened and when you noticed it;
- what kind of data is involved and roughly how many people are affected;
- whether the data was encrypted;
- what you have already done.

Do not:

- try to investigate on your own or "fix it quietly";
- delete emails, logs or files, because they are evidence;
- contact the affected people, the customer or the authorities yourself;
- discuss the breach on social media or outside the response team.

You **may** take obvious, immediate containment steps, such as asking a wrong email recipient to delete the email and confirm in writing, or disabling a public sharing link.

3. Step 2: triage and containment (Incident Response Team)

The Incident Response Team (IRT), led by the Security Operations Manager, starts triage **within 4 hours** of the report. The IRT:

1. confirms whether a breach has happened;
2. contains it (for example by revoking access, resetting credentials or restoring from backup);
3. assigns a severity level;
4. informs the DPO about every incident that involves personal data.

Severity	Description	Examples
Low	Small number of people, low-sensitivity data, contained quickly.	One internal email with a colleague's phone number sent to the wrong colleague.
Medium	Limited data of customers or employees exposed outside Corvane.	A spreadsheet with 40 customer contact names sent to the wrong supplier.
High	Large volume, or Confidential data with real risk of harm.	A misconfigured storage bucket exposing thousands of driver records.
Critical	Restricted or special-category data, or an ongoing attack.	Ransomware with confirmed data theft, or leaked health data.

4. Step 3: risk assessment and notification (DPO)

The DPO assesses the risk to the people affected, considering the type and sensitivity of the data, the number of people, whether the data was encrypted, and how easy it is to identify individuals.

When Corvane is the controller (for example employee data):

- If the breach is likely to result in a risk to people's rights and freedoms, the DPO notifies the competent supervisory authority **within 72 hours of Corvane becoming aware** of the breach (GDPR Article 33). If not all information is available, the DPO notifies in phases rather than waiting.
- If the breach is likely to result in a **high risk** to people, Corvane also informs the affected people **without undue delay** (GDPR Article 34), in clear and plain language, with advice on how to protect themselves.
- Notification to individuals is not required if the data was protected by strong encryption and the key was not compromised.

When Corvane is the processor (data that customers put into Corvane products):

- Corvane does not notify the authority itself. It notifies the affected **customer**, who is the controller.
- Corvane's standard Data Processing Agreement commits Corvane to notify the customer **within 24 hours** of becoming aware of the breach. The Customer Success Manager sends the notification together with the DPO.

5. Step 4: record every breach

Every personal data breach is recorded in the **Breach Register**, even if it was not notified to the authority or to individuals. The record includes the facts, the effects, the decisions taken (including the reasons for not notifying) and the remedial actions. The supervisory authority can ask to see the Register at any time.

6. Step 5: learn and improve

For every High or Critical breach, the IRT holds a blameless **post-incident review within 10 working days** of closing the incident. The review identifies root causes and actions to prevent a repeat, each with an owner and a due date. A summary is shared with the Security Steering Committee every quarter.

7. Quick reference

When	Who	What
Within 1 hour of discovery	Anyone	Report to the Security Desk (ext. 4444).
Within 4 hours of the report	Incident Response Team	Start triage and containment, inform the DPO.
Within 24 hours of awareness	Customer Success + DPO	Notify the customer (when Corvane is processor).
Within 72 hours of awareness	DPO	Notify the supervisory authority (when Corvane is controller and there is a risk).
Without undue delay	DPO	Inform affected people (when there is a high risk).
Within 10 working days of closure	Incident Response Team	Post-incident review for High and Critical breaches.

Fictional sample document created for the KnowGauge demo. Corvane Systems is not a real company, and this document is not legal or HR advice.